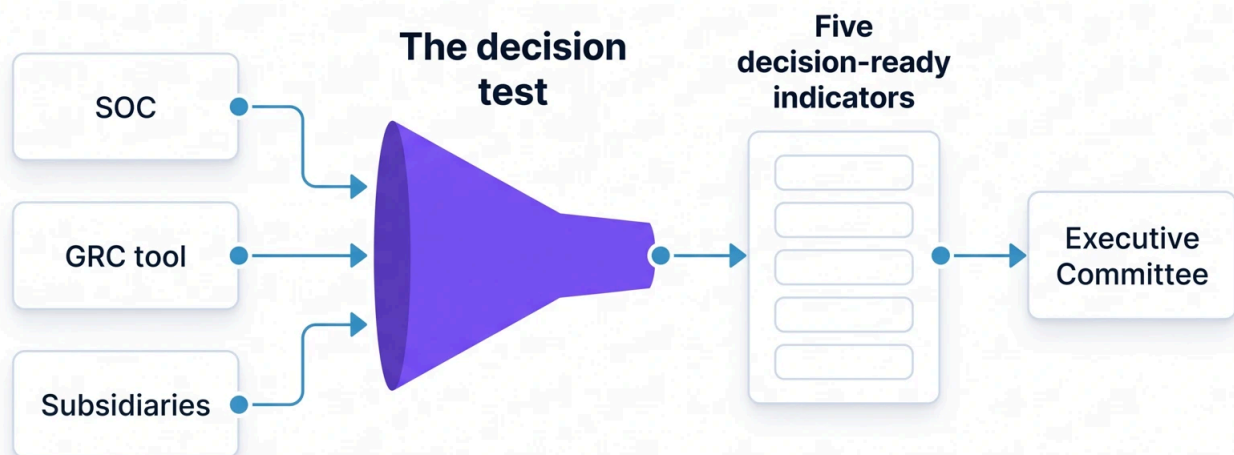


The CISO's briefing: Indicators for the executive committee

Five figures for ten minutes of committee time



Session objectives

By the end of this sequence:

- **Distinguish** a strategic indicator from a technical metric, and know which of the two belongs in an executive committee meeting
- **Build** an executive report: few indicators, each linked to a decision the executive team can take
- **Translate** a technical measurement into executive language without betraying it

- **Spot** vanity indicators, the ones that reassure without informing, and rule them out with a reasoned argument.

Prerequisites

- The KPI and KRI indicators established from session 1 onwards: the KPI measures the effectiveness of a security measure, the KRI warns about risk exposure. They are handled here, not redefined.
- The executive dashboard sketched in session 1 for the MERIDIAN group, with its four target indicators: coverage of the PSSI (information security policy), average detection time, system obsolescence, awareness training rate.
- The audit report from session 4 and the initial assessment from session 8: the data reserves the indicators will be drawn from.

What must be in place before the exercise

Three notions, ten minutes, and they hold together.

The notion of executive reporting comes first. The problem it solves is one of attention, not of data. A management team has a few minutes a month for security, while the SOC, the GRC tool and the subsidiaries produce thousands of data points. Executive reporting is the discipline that converts that flow into a few decidable pieces of information. What goes up to the committee is not what is available: it is what calls for or informs a decision at its level.

Its mechanics: start from the decisions the committee can take, budgets, trade-offs, priorities, risk acceptances, and work back to the data that informs them. Never the reverse. Its limit: it aggregates, so it loses detail. Good executive reporting owns that loss and gives the path to the detail. It does not claim to contain it.

The strategic indicator comes next. It is an indicator chosen to inform a decision at the strategic level, the one session 1 defined: the Board of Directors and Executive Management, the risk appetite, the orientations. A strategic indicator answers a question management really asks itself:

- are we more exposed than last quarter?
- is the money invested producing risk reduction?
- are we meeting our obligations?

At the opposite end, a technical metric answers an engineer's question: how many open vulnerabilities on the estate, how many alerts handled this week. Both are useful, but not on the same floor. The metric feeds the indicator, it does not go up to the committee as is. The membership test holds in one question: if the indicator turns red, does the committee know what to decide? If it can only frown and ask for a report, the indicator was not at its level.

Strategic indicator

Informs a committee decision

Technical metric

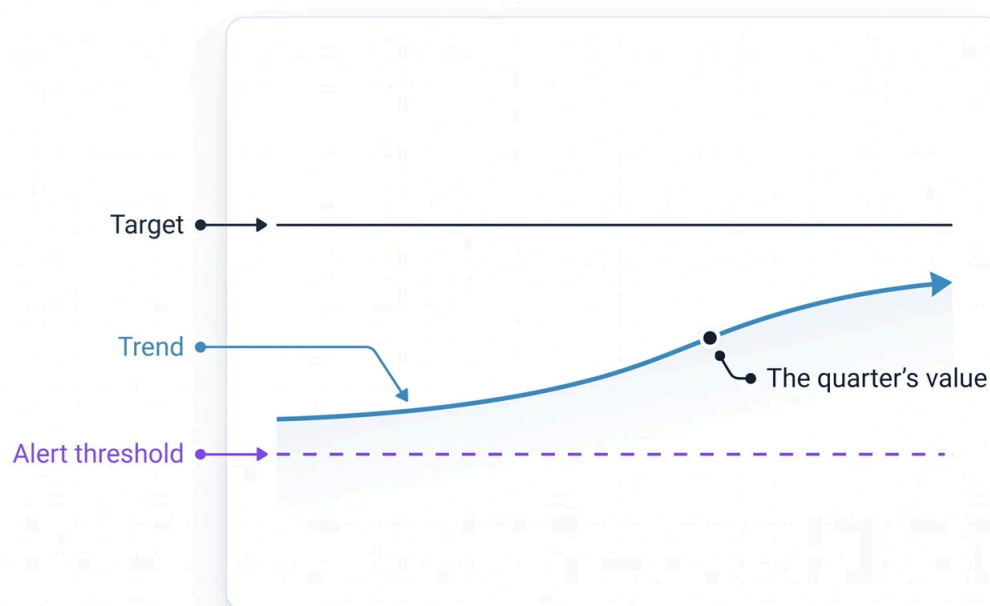
Feeds the indicator, stays at the operational level

Vanity indicator

Reassures without informing: to be set aside

The strategic dashboard comes last: the ordered assembly of these indicators, each with a target, an alert threshold and a trend. The important word is trend. An isolated value says almost nothing, the trajectory is what informs. That is why a dashboard is built to last: same indicators, same definitions, month after month.

Its limit is known to every CISO and discovered by every management team: a dashboard only measures what or decided to put in it, and it can be green while a blind spot burns.



💡 Golden rule of executive reporting: every indicator on the dashboard must be presentable in a sentence of the form "this figure tells you whether..., and if it crosses the threshold, the decision to take is...". If the sentence cannot be finished, the indicator moves down a floor.

Case study: the Chief Executive Officer's brief

Scenario and problem statement

The module's home straight. The Chief Executive Officer of the MERIDIAN group sent this message to the Group CISO (RSSI Groupe): "I received the monthly monitoring report: forty pages, I only read the first one. Next week, the Executive Committee is devoting thirty minutes to security before the budget review. I want a one-page dashboard: five indicators, not one more. If an indicator is red, I want to know what to decide. Over to you."

The Group CISO's deputy, full of goodwill, has prepared a first list of candidates, drawn from the group's tools:

Candidate	What the tool measures today
1	Number of alerts handled by the SOC over the month
2	Share of privileged accounts protected by multi-factor authentication
3	Number of attacks blocked by the group's firewalls
4	Share of systems running an OS version no longer maintained by its vendor
5	Average detection time for security incidents
6	Number of tickets opened by the infrastructure team
7	Share of employees who completed awareness training over the last twelve months
8	Volume of logs collected per day into the centralized SOC
9	Share of critical audit findings unresolved after thirty days
10	Share of subsidiaries covered by the group's framework PSSI
11	Availability rate of the group's corporate website
12	Share of major incidents reported to the Group CISO within the two-hour deadline set by the group's directive INC-01

The deputy attached to the list the past quarter's readings for the four target indicators the group set itself in session 1, calculated at group level, all subsidiaries together:

Session 1 target indicator	Quarter's reading, group level
PSSI coverage	82%
Average detection time	5 hours
System obsolescence	9%
Awareness training rate	64%

These four readings hold for the whole day: the lecture takes them up in its examples. The framework policy directives as codified in session 1 (ACC-01 to COR-01) are authoritative for this exercise, whatever wording the group adopted.

Guided questions

1. **Classify** the twelve candidates into three families: strategic indicator presentable as is, technical metric to aggregate or translate before any presentation, vanity indicator to discard. Each classification with half a sentence of justification.
2. **Select** the five indicators for the committee, respecting the brief. Construction constraint: at least one indicator of compliance with the group's rules, at least one indicator of risk exposure, at least one indicator focused on incident response.
3. **Complete** each selected indicator: the target, the alert threshold, and the golden-rule sentence, "this figure tells you whether..., and if it crosses the threshold, the decision to take is...". Build on the targets the group set in session 1 where they exist.
4. **Translate** candidate 5, the average detection time, into executive language: three sentences at most, without the word "logs", saying what it measures, why it matters, and what is decided if it drifts.
5. **Draft** the Group CISO's reply to the deputy about candidate 3, the number of blocked attacks, which the deputy finds "very compelling for the executive team". Two sentences: the fundamental flaw of this indicator, and what is proposed instead.

Working method

Allow 10 minutes for the classification, 10 for the selection and thresholds, 10 for the two written answers. Work with the recipient's question in mind at every line: not "is this figure interesting?" but "can the Executive Committee decide something upon seeing it?".



Answer keys and assessment criteria – cliquer pour révéler